

ZAP by Checkmarx Scanning Report

Generated with  [The ZAP logo](#) on Tue 11 Aug 2026, at 15:08:23

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

1. [About This Report](#)
 1. [Report Parameters](#)
2. [Summaries](#)
 1. [Alert Counts by Risk and Confidence](#)
 2. [Alert Counts by Site and Risk](#)
 3. [Alert Counts by Alert Type](#)
 4. [Insights](#)
3. [Alerts](#)
 1. [Risk=High, Confidence=Low \(1\)](#)
 2. [Risk=Medium, Confidence=High \(2\)](#)
 3. [Risk=Medium, Confidence=Medium \(2\)](#)
 4. [Risk=Low, Confidence=High \(1\)](#)
 5. [Risk=Low, Confidence=Medium \(2\)](#)
 6. [Risk=Low, Confidence=Low \(1\)](#)
 7. [Risk=Informational, Confidence=Medium \(3\)](#)
 8. [Risk=Informational, Confidence=Low \(2\)](#)
4. [Appendix](#)
 1. [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://firefox-settings-attachments.cdn.mozilla.net>
- <https://firefox.settings.services.mozilla.com>
- <http://localhost:3000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	1 (7.1%)	1 (7.1%)
	Medium	0 (0.0%)	2 (14.3%)	2 (14.3%)	0 (0.0%)	4 (28.6%)
	Low	0 (0.0%)	1 (7.1%)	2 (14.3%)	1 (7.1%)	4 (28.6%)
	Informational	0 (0.0%)	0 (0.0%)	3 (21.4%)	2 (14.3%)	5 (35.7%)
	Total	0 (0.0%)	3 (21.4%)	7 (50.0%)	4 (28.6%)	14 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
https://firefox-settings-attachments.cdn.mozilla.net		0 (0)	0 (0)	1 (1)	0 (1)
Site https://firefox.settings.services.mozilla.com		0 (0)	0 (0)	1 (1)	2 (3)
http://localhost:3000		1 (1)	4 (5)	2 (7)	3 (10)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
<u>SQL Injection</u>	High	1 (7.1%)
<u>Content Security Policy (CSP) Header Not Set</u>	Medium	5 (35.7%)
<u>Cross-Domain Misconfiguration</u>	Medium	5 (35.7%)
<u>Missing Anti-clickjacking Header</u>	Medium	1 (7.1%)
<u>Session ID in URL Rewrite</u>	Medium	5 (35.7%)
<u>Private IP Disclosure</u>	Low	1 (7.1%)
<u>Strict-Transport-Security Header Not Set</u>	Low	1 (7.1%)
<u>Timestamp Disclosure - Unix</u>	Low	10 (71.4%)
<u>X-Content-Type-Options Header Missing</u>	Low	5 (35.7%)
<u>Information Disclosure - Suspicious Comments</u>	Informational	3 (21.4%)
<u>Modern Web Application</u>	Informational	5 (35.7%)
<u>Re-examine Cache-control Directives</u>	Informational	1 (7.1%)
<u>Retrieved from Cache</u>	Informational	2 (14.3%)
<u>User Agent Fuzzer</u>	Informational	5 (35.7%)
Total		14

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	14
Low	Warning		ZAP warnings logged - see the zap.log file for details	16
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	65 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 3xx	3 %

Level	Reason	Site	Description	Statistic
Info	Exceeded Low	http://localhost:3000	Percentage of responses with status code 4xx	27 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 5xx	3 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	7 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	7 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/octet-stream	5 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type font/woff2	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/jpeg	11 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/png	5 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/x-icon	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/css	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	53 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/markdown	3 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/plain	3 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	98 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method POST	1 %
Info	Informational	http://localhost:3000	Count of total endpoints	97
Info	Informational	http://localhost:3000	Percentage of slow responses	3 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with content type application/octet-stream	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of slow responses	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://firefox.settings.services.mozilla.com	Count of total endpoints	1
Info	Informational	https://firefox.settings.services.mozilla.com	Percentage of slow responses	100 %

Alerts

1. Risk=High, Confidence=Low (1)

1. http://localhost:3000 (1)

1. [SQL Injection](#) (1)

1. ► GET http://localhost:3000/rest/products/search?q=%27%28

2. Risk=Medium, Confidence=High (2)

1. http://localhost:3000 (2)

1. [Content Security Policy \(CSP\) Header Not Set](#) (1)

1. ► GET http://localhost:3000/sitemap.xml

2. [Session ID in URL Rewrite](#) (1)

1. ► GET http://localhost:3000/socket.io/?
EIO=4&transport=polling&t=P_oCIk0&sid=P7m_urzN8VAsp3_HAAAC

3. Risk=Medium, Confidence=Medium (2)

1. http://localhost:3000 (2)

1. [Cross-Domain Misconfiguration](#) (1)

1. ► GET http://localhost:3000/robots.txt

2. [Missing Anti-clickjacking Header](#) (1)

1. ► POST http://localhost:3000/socket.io/?
EIO=4&transport=polling&t=P_oCIjy&sid=P7m_urzN8VAsp3_HAAAC

4. Risk=Low, Confidence=High (1)

1. https://firefox-settings-attachments.cdn.mozilla.net (1)

1. [Strict-Transport-Security Header Not Set](#) (1)

1. ► GET https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

5. Risk=Low, Confidence=Medium (2)

1. https://firefox.settings.services.mozilla.com (1)

1. [X-Content-Type-Options Header Missing](#) (1)

1. ► GET https://firefox.settings.services.mozilla.com/v1/

2. http://localhost:3000 (1)

1. [Private IP Disclosure](#) (1)

1. ► GET http://localhost:3000/rest/admin/application-configuration

6. Risk=Low, Confidence=Low (1)

1. http://localhost:3000 (1)

1. [Timestamp Disclosure - Unix](#) (1)

1. ► GET http://localhost:3000

7. Risk=Informational, Confidence=Medium (3)

1. https://firefox.settings.services.mozilla.com (1)

1. [Retrieved from Cache](#) (1)

1. ► GET https://firefox.settings.services.mozilla.com/v1/

2. http://localhost:3000 (2)

1. [Modern Web Application](#) (1)

1. ► GET http://localhost:3000/sitemap.xml

2. [User Agent Fuzzer](#) (1)

1. ► GET http://localhost:3000/socket.io/?EIO=4&transport=polling&t=P_oCNmO

8. Risk=Informational, Confidence=Low (2)

1. https://firefox.settings.services.mozilla.com (1)

1. [Re-examine Cache-control Directives](#) (1)

1. ► GET https://firefox.settings.services.mozilla.com/v1/

2. http://localhost:3000 (1)

1. [Information Disclosure - Suspicious Comments](#) (1)

1. ► GET http://localhost:3000/main.js

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

1. SQL Injection

Source raised by an active scanner ([SQL Injection](#))

CWE ID [89](#)

WASC ID 19

Reference 1. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

2. Content Security Policy (CSP) Header Not Set

Source raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))

CWE ID [693](#)

WASC ID 15

1. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
3. <https://www.w3.org/TR/CSP/>
4. <https://w3c.github.io/webappsec-csp/>
5. <https://web.dev/articles/csp>
6. <https://caniuse.com/#feat=contentsecuritypolicy>
7. <https://content-security-policy.com/>

Reference

3. Cross-Domain Misconfiguration

Source raised by a passive scanner ([Cross-Domain Misconfiguration](#))

CWE ID [264](#)

WASC ID 14

Reference 1. <https://vulnecat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy>

4. Missing Anti-clickjacking Header

Source raised by a passive scanner ([Anti-clickjacking Header](#))

CWE ID [1021](#)

WASC ID 15

Reference 1. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options>

5. Session ID in URL Rewrite

Source raised by a passive scanner ([Session ID in URL Rewrite](#))

CWE ID [598](#)

WASC ID 13

Reference 1. <https://seclists.org/webappsec/2002/q4/111>

6. Private IP Disclosure

Source raised by a passive scanner ([Private IP Disclosure](#))

CWE ID [497](#)

WASC ID 13

Reference 1. <https://datatracker.ietf.org/doc/html/rfc1918>

7. Strict-Transport-Security Header Not Set

Source raised by a passive scanner ([Strict-Transport-Security Header](#))

CWE ID [319](#)

WASC ID 15

- Reference**
1. https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
 2. <https://owasp.org/www-community/Security-Headers>
 3. https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
 4. <https://caniuse.com/stricttransportsecurity>
 5. <https://datatracker.ietf.org/doc/html/rfc6797>

8. Timestamp Disclosure - Unix

Source raised by a passive scanner ([Timestamp Disclosure](#))

CWE ID [497](#)

WASC ID 13

- Reference**
1. <https://cwe.mitre.org/data/definitions/200.html>

9. X-Content-Type-Options Header Missing

Source raised by a passive scanner ([X-Content-Type-Options Header Missing](#))

CWE ID [693](#)

WASC ID 15

- Reference**
1. [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))
 2. <https://owasp.org/www-community/Security-Headers>

10. Information Disclosure - Suspicious Comments

Source raised by a passive scanner ([Information Disclosure - Suspicious Comments](#))

CWE ID [615](#)

WASC ID 13

11. Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

12. Re-examine Cache-control Directives

Source raised by a passive scanner ([Re-examine Cache-control Directives](#))

CWE ID [525](#)

WASC ID 13

- Reference**
1. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
 2. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
 3. <https://grayduck.mn/2021/09/13/cache-control-recommendations/>

13. Retrieved from Cache

Source raised by a passive scanner ([Retrieved from Cache](#))

CWE ID [525](#)

- Reference**
1. <https://datatracker.ietf.org/doc/html/rfc7234>
 2. <https://datatracker.ietf.org/doc/html/rfc7231>
 3. <https://www.rfc-editor.org/rfc/rfc9110.html>

14. User Agent Fuzzer

Source raised by an active scanner ([User Agent Fuzzer](#))

Reference 1. <https://owasp.org/wstg>